The SAP GRC Security Career Guide

What the job is, what employers ask for, and how to get ready for your first role

This guide is for people moving into SAP Security and GRC Access Control — junior SAP consultants, auditors, administrators and career changers. It explains the work in plain language, using what current job postings actually ask for. It is free, and it is not a sales brochure: most of what follows is useful whether or not you ever take a TIB course.

1. What an SAP GRC Security consultant does

Every company that runs SAP has to control who can do what in the system. A user who can both create a vendor and pay that vendor can move money with nobody checking. A role that is slightly too broad can expose payroll or let someone approve their own purchase. SAP Security and GRC Access Control are how companies design, build, monitor and fix that access.

The work follows the life of an SAP project, and most consultants touch all four stages:

Stage	What you do	Typical tools
Design & blueprint	Turn business requirements into role designs, naming standards, SoD rules and approval workflows a build team can follow.	Role matrices, SoD rulesets, MSMP design
Configuration & build	Build roles, rulesets, workflows and Fiori content in the system — and prove they work.	PFCG, SU24, GRAC_SPM, BRFPLUS, /UI2/FLPD_CUST
Go-live & cutover	Load access for hundreds of users, triage hypercare tickets, make go/no-go calls, answer auditors.	LSMW, SU53, STAUTHTRACE, GRC connectors
Post-go-live support	Fix the reported access problem first, check a few neighbours, then decide whether a wider review is needed.	SUIM, SU01, ARA, Firefighter logs

2. The job titles you will see

In October 2026 TIB consolidated 18 open SAP Security and GRC consultant postings from Dice and Indeed — consultancies, manufacturers, retailers, government contractors and Big 4 firms — into one composite job description. These are the titles in those postings:

- SAP Security Consultant
- SAP GRC Access Control Consultant / Analyst
- SAP Security Administrator
- S/4HANA & Fiori Security Analyst
- SAP GRC / IAG Identity Analyst
- SAP Security & GRC Support Analyst

Advertised pay in those postings ran roughly $75,000–$207,000 a year for permanent roles, depending on seniority, and about $45–$88 an hour for contract roles. These are ranges taken from the postings, not a promise of salary or employment. Most postings asked for four or more years of experience — which is why practical, scenario-based preparation matters so much for a first role.

3. The eight skill areas employers ask for

Skill area	What it means in practice
Role design and build	Single, composite and derived roles in PFCG; org-level

	derivation; SU24 defaults; naming standards; transports.
User administration & troubleshooting	SU01 and SU10; diagnosing "no authorization" with SU53, STAUTHTRACE and SUIM; mass role loads.
GRC Access Control	Access Risk Analysis and rulesets, Access Request Management with MSMP/BRF+, Firefighter (EAM), Business Role Management, User Access Review, mitigating controls.
Fiori and front-end security	Catalogs, spaces, pages and tiles; OData services, ICF nodes and S_SERVICE; matching front-end and back-end access.
Cloud identity	BTP role collections, SAP Cloud Identity Services (IAS, IPS) and Identity Access Governance (IAG) — the fastest-growing requirement in the postings.
Privileged & technical access	SAP*, DDIC and default users; user types and S_RFC; the Security Audit Log; HANA database users.
Projects, SOX and audit	The security workstream from blueprint to hypercare; SOX access evidence for internal and external auditors.
Judgement & communication	Explaining an access failure to an auditor, a developer and a business owner — and holding a correct position under pressure.

4. What a normal week looks like

- **Tickets:** a user cannot post an invoice; you trace the missing authorization with SU53 or a trace, find the approved role that grants it, and route it through access request — without creating a conflict.
- **Changes:** a new custom transaction needs SU24 proposals and a place in the role design before it can be released.
- **Reviews:** a quarterly access review is due; you make sure reviewers see something they can actually judge, and that removals really happen.
- **Audit requests:** an auditor asks for every Firefighter session last quarter and evidence each one was reviewed.
- **Projects:** a Fiori rollout or a new acquisition needs roles designed, built and tested before go-live.

5. How careers usually progress

Stage	Typical focus
Security administrator / support analyst	User administration, tickets, role assignments, first-line troubleshooting.
SAP Security consultant	Role design and build, Fiori security, project work from blueprint to hypercare.
GRC Access Control consultant	Rulesets, workflows, Firefighter, access reviews, GRC configuration.
Senior consultant / security lead	Owning the security workstream, cloud identity, audit readiness, leading a team.

6. Six interview questions to practise

Interviewers rarely ask you to recite a transaction code. They ask what you would do. Practise answering these out loud:

- A user gets "no authorization" in a Fiori app, but their role looks correct. Where do you look, in what order?
- The quarterly SoD report has shown almost no violations for a year. Is that good news? How would you check?

- A request is stuck at a compliance approval stage. Would you let it auto-approve after a timeout? Why or why not?
- How do you split a role that is too broad without breaking someone's legitimate access?
- An auditor asks for evidence that Firefighter sessions were reviewed. What do you give them — and what would not be enough?
- A business owner says the mitigating control "is in place". What evidence would you ask for?

7. How to prepare — with or without a course

- **Learn the screens first:** SAP GUI, Fiori Launchpad, SPRO, PFCG, SU24, SU01 and GRAC_SPM. Navigation should not use up your thinking.
- **Practise on a real system:** reading about PFCG is not the same as building a derived role. Use a training system and a practice namespace — never production.
- **Diagnose before you fix:** write down what is broken, why it matters and what the fix must achieve before you open a transaction.
- **Practise the pushback:** every fix you make, explain it to an imaginary auditor, developer and business owner. That is what interviews and first engagements test.
- **Keep evidence:** screenshots with the selection screen, exports, and a short write-up for each exercise make a portfolio you can talk about.

8. How TIB's SAP GRC Security & Fiori Labs fits in

If you want structured, live practice, TIB's course runs in two levels, taught live by an instructor on a real S/4HANA and GRC training system, with 5 seats per class time:

- **Intermediate: Design & Build ($950)** — 16 live sessions over 4 weeks. Foundations as pre-work, then design-then-build labs: roles, SoD rulesets, Firefighter, MSMP/BRF+ workflows, Fiori Launchpad and OData security, troubleshooting tickets.
- **Advanced: Go-Live, Support & Cloud ($850)** — 12 live sessions over 3 weeks: evidence readiness, mass loads, go/no-go calls, hypercare, provisioning failures, privileged access, cloud identity, BRM, access reviews and auditor requests.
- **Both levels ($1,650)** — 28 live sessions; a certificate for each level.

Course work builds practical skill and interview readiness. It is not the same as production project experience, and TIB does not describe it that way. TIB Systems is an independent training provider; the course is not endorsed by SAP SE.

See the labs and open dates: grc-security-fiori-student-console.vercel.app/course.html

Questions: academy@tib-systems.com